

CÓMO CONVERTIRSE EN ANALISTA SOC

*Guía práctica para operaciones de seguridad, SIEM, triaje de alertas,
búsqueda de amenazas, respuesta a incidentes y preparación
profesional*

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

CC BY-NC-SA 4.0

Propósito y aviso de uso ético

Este manual ofrece una ruta práctica hacia las operaciones de seguridad. Utilice herramientas, registros, capturas de red, muestras y técnicas de investigación únicamente en sistemas propios, laboratorios aprobados o entornos para los que tenga autorización explícita.

La capacidad técnica no crea permiso. Proteja la privacidad, preserve la evidencia, respete el alcance y escale cuando una investigación pueda afectar a personas, obligaciones legales u operaciones empresariales.

Tabla de contenido

- 1. Qué hace un analista SOC
- 2. Funciones y progresión profesional
- 3. Conocimientos fundamentales
- 4. Registros y telemetría
- 5. Plataformas SIEM
- 6. Flujo de triaje de alertas
- 7. Investigaciones de endpoints
- 8. Investigaciones de identidad
- 9. Investigaciones de red
- 10. Correo y phishing
- 11. Investigaciones en la nube
- 12. MITRE ATT&CK e inteligencia de amenazas
- 13. Ingeniería de detección
- 14. Búsqueda de amenazas
- 15. Respuesta a incidentes
- 16. Gestión de casos e informes
- 17. Laboratorio seguro
- 18. Proyectos de portafolio
- 19. Currículum y entrevistas
- 20. Plan de 30, 60 y 90 días
- 21. Accesibilidad y aprendizaje sostenible
- 22. Listas y plantillas
- 23. Glosario
- 24. Recursos oficiales

1. Qué hace un analista SOC

Un analista de un Centro de Operaciones de Seguridad monitorea datos, investiga actividad sospechosa, documenta hallazgos y ayuda a coordinar la respuesta. Convierte grandes volúmenes de señales técnicas en decisiones claras: cerrar como benigno, continuar, contener o escalar.

Responsabilidad	Ejemplo práctico
Monitorear	Revisar colas de SIEM, alertas de endpoint, riesgos de identidad y hallazgos de nube.
Realizar triaje	Determinar si una alerta es positiva real, falsa, actividad esperada o no resuelta.
Investigar	Construir una línea de tiempo con usuarios, equipos, IP, procesos, archivos y autenticaciones.
Responder	Contener según la autoridad o entregar recomendaciones claras.
Documentar	Registrar evidencia, razonamiento, impacto, acciones y seguimiento.
Mejorar	Ajustar reglas ruidosas, identificar vacíos de telemetría y proponer detecciones.

2. Funciones y progresión profesional

Nivel	Enfoque habitual	Evidencia de preparación
Nivel 1 / Junior	Monitoreo, enriquecimiento, triaje básico y phishing	Notas consistentes, escalamiento correcto y consultas básicas
Nivel 2 / Analista	Investigaciones más profundas de endpoint, identidad, red y nube	Líneas de tiempo, alcance, hunting y retroalimentación
Nivel 3 / Senior	Investigaciones avanzadas, hunting e ingeniería de detección	Casos complejos, mentoría y análisis multiplataforma
Líder / Gerente	Operaciones, métricas, personal, calidad y comunicación	Mejora del programa, gobierno e informes ejecutivos
Ingeniero de detección / Hunter	Analítica, reglas, hipótesis y validación	Detecciones versionadas, pruebas y cobertura

3. Conocimientos fundamentales

- Redes: TCP/IP, DNS, HTTP/S, puertos, NAT, VPN, proxies, firewalls y protocolos comunes.
- Windows: procesos, servicios, registro, eventos, PowerShell, tareas programadas y autenticación.

- Linux: procesos, permisos, servicios, registros, historial de shell, SSH y cron.
- Identidad: usuarios, grupos, MFA, SSO, tokens, acceso condicional, privilegios y cuentas de servicio.
- Nube: cuentas, suscripciones, IAM, auditoría, almacenamiento, cómputo, red y responsabilidad compartida.
- Seguridad: malware, phishing, robo de credenciales, movimiento lateral, persistencia, exfiltración y ransomware.
- Habilidades humanas: escritura clara, curiosidad, escalamiento tranquilo, preservación de evidencia y privacidad.

4. Registros y telemetría

Fuente	Qué puede responder
Endpoint / EDR	¿Qué proceso se ejecutó? ¿Qué archivo cambió? ¿Qué conexión se realizó?
Eventos de Windows	¿Quién inició sesión? ¿Qué servicio, tarea, grupo o política cambió?
Proveedor de identidad	¿Se usó MFA? ¿El inicio fue riesgoso o desde un dispositivo nuevo?
DNS	¿Qué dominios se consultaron, desde qué equipo y cuándo?
Firewall / proxy	¿Qué conexiones se permitieron o bloquearon? ¿Cuántos datos se movieron?
Seguridad de correo	¿Quién envió el mensaje? ¿Qué URL, adjuntos y resultados de autenticación tenía?
Auditoría de nube	¿Quién cambió un recurso, rol, política, clave o regla de red?
Aplicaciones	¿Qué acción ocurrió dentro de la aplicación empresarial?

El análisis depende de la sincronización horaria, identificadores estables, retención útil, campos normalizados y conocimiento de los datos faltantes. La ausencia de un registro no prueba que un evento no ocurrió.

5. Plataformas SIEM

Un SIEM recopila, normaliza, busca, correlaciona y presenta datos de seguridad. Entre las plataformas comunes se encuentran Microsoft Sentinel, Splunk Enterprise Security, Elastic Security, Wazuh y Security Onion. Aprenda primero los conceptos: ingestión, esquemas, consultas, detecciones, colas, casos, enriquecimiento, automatización y retención.

Plataforma	Enfoque inicial
Microsoft Sentinel	KQL, reglas analíticas, incidentes, entidades, workbooks y automatización.

Splunk	SPL, campos, modelos de datos, eventos notables y paneles.
Elastic Security	KQL/Lucene, alertas, líneas de tiempo, casos y datos de endpoint/nube.
Wazuh	Agentes, integridad de archivos, vulnerabilidades, reglas y panel.
Security Onion	Monitoreo de red, Zeek, Suricata, paquetes y casos.

6. Flujo de triaje de alertas

1. Leer el título, la lógica de la regla, el intervalo, la severidad y la fuente.
2. Confirmar usuario, equipo, IP, aplicación y clasificación de datos.
3. Validar que la telemetría esté completa y la zona horaria sea correcta.
4. Enriquecer con criticidad, función, reputación, inteligencia y cambios recientes.
5. Construir una línea de tiempo antes de concluir.
6. Comparar con la línea base y actividad aprobada.
7. Decidir: falso positivo, verdadero benigno, sospechoso, incidente confirmado o evidencia insuficiente.
8. Contener o escalar según la autoridad y el procedimiento.
9. Documentar hechos, razonamiento, acciones e incertidumbre.
10. Entregar retroalimentación sobre ajustes o vacíos de telemetría.

Preguntas de triaje

- ¿Qué activó exactamente la alerta?
- ¿Qué evidencia respalda una intención maliciosa?
- ¿Puede ser administración, automatización, prueba o viaje legítimo?
- ¿Qué ocurrió inmediatamente antes y después?
- ¿La actividad aparece en otras personas o equipos?
- ¿Cuál es el impacto empresarial potencial?
- ¿Qué acción está autorizada ahora?

7. Investigaciones de endpoints

- Identifique árbol de procesos, línea de comandos, relaciones padre-hijo, usuario, hashes, firmas, persistencia y conexiones.
- Confirme si el ejecutable es esperado para ese equipo y usuario.
- Revise descargas, historial, adjuntos, medios extraíbles e instalaciones cuando esté autorizado.
- Busque tareas programadas, servicios, inicio automático, claves Run, WMI y PowerShell inusual.
- No elimine evidencia antes de preservarla y coordinar.

8. Investigaciones de identidad

- Revise inicios exitosos y fallidos, MFA, dispositivo, ubicación, IP, agente de usuario, tokens y riesgos.
- Compare con el patrón normal y viajes o VPN aprobados.
- Revise restablecimientos, grupos, nuevas credenciales, reglas de correo, consentimientos OAuth y roles.
- Trate el viaje imposible como pista, no como prueba automática.
- Revoque sesiones, restablezca credenciales o deshabilite cuentas solo con autorización.

9. Investigaciones de red

- Comience con origen, destino, protocolo, puerto, dirección, bytes, duración y acción.
- Combine DNS, proxy, firewall, VPN, Zeek, Suricata y paquetes.
- Busque beaconing, destinos raros, dominios nuevos, protocolos inesperados, movimiento lateral y transferencias grandes.
- No declare malicioso un tráfico solo por usar un puerto poco común.
- Las capturas pueden contener credenciales y datos personales; restrinja acceso y retención.

10. Correo y phishing

- Preserve el mensaje original y sus encabezados.
- Revise dominio, reply-to, return-path, SPF, DKIM, DMARC, URL, adjuntos y suplantación.
- Use un entorno seguro; no abra adjuntos sospechosos en un equipo productivo.
- Busque otros destinatarios y mensajes relacionados.
- Determine si alguien hizo clic, ingresó credenciales, ejecutó archivos o aprobó MFA.
- Bloquee indicadores y retire mensajes solo mediante procedimientos autorizados.
- Comuníquese sin culpar al usuario.

11. Investigaciones en la nube

- Identifique cuenta, inquilino, suscripción/proyecto, recurso, identidad, acción, IP, agente y hora.
- Revise cambios de IAM, claves nuevas, exposición pública, red, almacenamiento, cómputo y auditoría.
- Distinga acciones del plano de administración del acceso a datos.
- Revise infraestructura como código y canalizaciones aprobadas.
- Preserve auditoría y registre identificadores de recursos.

12. MITRE ATT&CK e inteligencia de amenazas

MITRE ATT&CK ofrece un lenguaje común para tácticas y técnicas. Úselo para describir comportamientos e identificar vacíos, no para forzar toda alerta dentro de una técnica. La inteligencia agrega contexto, pero una coincidencia es una pista, no una prueba final.

- Registre fuente, confianza, primera/última observación, alcance y vencimiento.
- Prefiera comportamiento y señales corroboradas a una sola reputación.
- Mapee detecciones y revise la cobertura con honestidad.
- Retire indicadores antiguos para reducir ruido.

13. Ingeniería de detección

11. Definir el comportamiento y la telemetría necesaria.
12. Escribir una hipótesis analítica clara.
13. Crear la consulta o regla y documentar campos.
14. Probar con datos seguros y conocidos.
15. Medir falsos positivos, puntos ciegos, latencia y costo.
16. Agregar severidad, entidades, enriquecimiento, respuesta y ATT&CK.
17. Versionar y conservar evidencia.
18. Ajustar con cuidado; no suprimir por conveniencia.

Pregunta de calidad	Ejemplo
Especificidad	¿La regla identifica comportamiento y no solo el nombre de una herramienta?
Contexto	¿Considera función, criticidad y administración esperada?
Capacidad de prueba	¿Una prueba segura reproduce la señal?
Accionabilidad	¿El analista sabe qué investigar después?
Mantenimiento	¿Tiene propietario, versión, fuente y fecha de revisión?

14. Búsqueda de amenazas

La búsqueda de amenazas es una búsqueda estructurada de actividad no detectada por alertas. Comience con una hipótesis basada en comportamiento, contexto, inteligencia o un vacío de control.

- Definir hipótesis y evidencia esperada.
- Identificar fuentes y limitaciones.
- Buscar ampliamente y reducir por tiempo, entidad, rareza y secuencia.
- Validar con telemetría adicional.
- Documentar hallazgos negativos y puntos ciegos.
- Convertir hallazgos repetibles en detecciones o controles.

15. Respuesta a incidentes

Fase	Contribución del SOC
Preparación	Procedimientos, contactos, herramientas, acceso, registros y ejercicios.
Detección y análisis	Validar, definir alcance, clasificar, preservar y notificar.
Contención	Recomendar o ejecutar aislamiento, bloqueo o revocación aprobados.
Erradicación y recuperación	Apoyar eliminación, restauración, validación y vigilancia.
Lecciones aprendidas	Línea de tiempo, causa, vacíos, métricas y acciones.

No exceda su autoridad. Un analista junior que escala rápido con buena evidencia está actuando correctamente.

16. Gestión de casos e informes

- Use un título preciso con la entidad y el comportamiento.
- Incluya zona horaria.
- Separe hechos, supuestos y conclusiones.
- Registre consultas, fuentes, acciones y comunicaciones.
- Explique el impacto en lenguaje claro.
- Indique qué sigue desconocido.
- Proteja datos personales y confidenciales.
- Use lenguaje neutral y no culpe a los usuarios.

Ejemplo de resumen

A las 14:22 UTC, la plataforma de identidad registró un inicio exitoso para jdoe desde una IP no asociada previamente. Se aprobó MFA. Cinco minutos después se creó una regla de reenvío. La persona confirmó que no realizó estas acciones. La cuenta fue deshabilitada y las sesiones revocadas según el procedimiento. El caso se escaló para revisar el buzón y evaluar notificaciones.

17. Laboratorio seguro

- Use un laboratorio virtual aislado y sin ruta a producción.
- Use usuarios y datos sintéticos. Nunca importe registros de clientes o empleadores sin permiso.
- Tome snapshots.
- Use sistemas intencionalmente vulnerables y plataformas autorizadas.
- No exponga servicios directamente a Internet.
- Mantenga muestras de malware fuera de laboratorios para principiantes salvo supervisión y aislamiento.

- Documente alcance, controles y limpieza.

Laboratorio sugerido

- Una máquina virtual Windows que genere eventos.
- Una máquina Linux.
- Wazuh o Elastic aislado, o un entorno controlado de aprendizaje de Sentinel.
- Sysmon cuando corresponda.
- Eventos simulados seguros.
- Repositorio GitHub con consultas, capturas y notas sanitizadas.

18. Proyectos de portafolio

Proyecto	Entregables
Investigación de phishing	Encabezados sanitizados, línea de tiempo, indicadores, conclusión y recomendaciones.
Investigación de Windows	Eventos, procesos, consultas, ATT&CK y limitaciones.
Detección SIEM	Regla, datos de prueba, resultado esperado, falsos positivos y ajuste.
Threat hunt	Hipótesis, fuentes, consultas, hallazgos, vacíos y detección propuesta.
Informe de incidente	Resumen ejecutivo, línea técnica, impacto, contención y lecciones.
Panel SOC	Propósito, fuentes, métricas, capturas y privacidad.

Nunca publique credenciales, datos de clientes, IP internas, indicadores privados, reglas propietarias o capturas productivas sin redactar.

19. Currículum y entrevistas

- Describa investigaciones con acción, evidencia y resultado.
- Distinga experiencia de laboratorio de experiencia productiva.
- Muestre consultas, informes y detecciones sanitizadas.
- Prepare la explicación de una alerta desde la señal hasta la disposición.
- Practique comunicar incertidumbre y escalamiento.
- No invente certificaciones, herramientas ni incidentes.

Ejemplos de logros

- Investigó alertas simuladas de endpoint e identidad en laboratorio, construyó líneas de tiempo y documentó decisiones de escalamiento.
- Creó y probó analíticas SIEM mapeadas a MITRE ATT&CK, con análisis de falsos positivos y ajustes.

- Produjo informes sanitizados de phishing e incidentes con evidencia, impacto y recomendaciones.

Preguntas comunes

- Explique su proceso de triaje.
- ¿Cómo distingue falso positivo de verdadero benigno?
- ¿Qué registros usaría para compromiso de cuenta?
- ¿Cómo investigaría PowerShell sospechoso?
- ¿Cuándo escalaría?
- ¿Cómo maneja telemetría faltante?
- Describa una detección creada o mejorada.
- ¿Cómo protege la privacidad?

20. Plan de 30, 60 y 90 días

Días 1 a 30

- Estudiar redes, Windows, Linux, identidad y ataques comunes.
- Aprender consultas básicas en un SIEM.
- Completar investigaciones simples de registros y phishing.
- Crear glosario y cuaderno.
- Publicar un informe sanitizado.

Días 31 a 60

- Practicar líneas de tiempo de endpoint, identidad, red y nube.
- Mapear a ATT&CK.
- Crear dos detecciones con pruebas.
- Completar una búsqueda de amenazas.
- Practicar mensajes de escalamiento.

Días 61 a 90

- Completar tres proyectos.
- Revisar diez vacantes e identificar habilidades repetidas.
- Adaptar el currículum sin exagerar.
- Practicar entrevistas.
- Aplicar a puestos SOC, monitoreo, incidentes y detección junior compatibles con ubicación y autorización.

21. Accesibilidad y aprendizaje sostenible

- Use transcripciones, subtítulos, laboratorios por teclado, documentos compatibles con lectores y texto ajustable.
- Divida investigaciones en listas repetibles.

- Use plantillas para reducir carga de memoria.
- Solicite adaptaciones razonables.
- Programe descansos durante colas largas o casos difíciles.
- Un buen analista se mide por juicio, evidencia y comunicación, no por velocidad de escritura o memoria perfecta.

22. Listas y plantillas

Lista de triaje

- Lógica entendida
- Zona horaria confirmada
- Entidades identificadas
- Contexto agregado
- Telemetría revisada
- Línea de tiempo construida
- Alertas relacionadas buscadas
- Hipótesis probadas
- Disposición seleccionada
- Acciones y evidencia documentadas
- Escalamiento o cierre aprobado
- Retroalimentación registrada

Plantilla de notas

Campo	Contenido
ID del caso	
Alerta / hipótesis	
Fecha y analista	
Usuarios y activos	
Hechos conocidos	
Línea de tiempo	
Consultas y evidencia	
Evaluación y confianza	
Acciones	
Preguntas pendientes	
Escalamiento / cierre	

23. Glosario

Término	Definición
Alerta	Señal generada por una regla, analítica, producto o control.
Caso / incidente	Registro gestionado con evidencia, análisis,

	decisiones y respuesta.
EDR	Detección y respuesta de endpoints.
Falso positivo	Alerta que indica incorrectamente el comportamiento objetivo.
Verdadero benigno	La regla observó correctamente el comportamiento, pero era autorizado o inocuo.
IOC	Indicador de compromiso.
SIEM	Gestión de información y eventos de seguridad.
SOAR	Orquestación, automatización y respuesta de seguridad.
Triaje	Validación, enriquecimiento, priorización y disposición inicial.
Búsqueda de amenazas	Búsqueda basada en hipótesis de comportamiento no detectado.

24. Recursos oficiales

[Microsoft Sentinel](#)

[MITRE ATT&CK](#)

[CISA - Respuesta a incidentes](#)

[Elastic Security](#)

[Wazuh - Inicio rápido](#)

[Splunk Enterprise Security](#)

[Sigma](#)

[YARA](#)

[Wireshark](#)

[Security Onion](#)

[CyberDefenders](#)

[LetsDefend](#)

[Blue Team Labs Online](#)

[Microsoft Learn - capacitación de Sentinel](#)

Verifique disponibilidad, costos, acceso regional y comportamiento vigente antes de depender de una plataforma. Las interfaces y licencias pueden cambiar.

Licencia

Copyright © 2026 Alberto (Al) Leiva. Licencia Creative Commons Atribución-NoComercial-CompartirIgual 4.0 Internacional (CC BY-NC-SA 4.0).